From Human-in-the-Loop to Continuous Defense: Cyber Threat Intelligence for Autonomous AI Agents

***Abstract*—The move from generative AI to autonomous agents broadens the cyber threat surface well beyond the application code and infrastructure to include the prompts, the retrieval pipelines, the memory, the model behaviour, the tool interfaces and the planning loops. Agents operate at machine speed, so a failure or an adversarial manipulation in one part of a multi-step workflow can cascade through the entire workflow, and human review on its own is simply not enough. This paper walks through the evolution of the AI attack surface across the web application era, the generative AI era and the agentic era and proposes a four-pillar security blueprint based on cyber threat intelligence: Threat Understanding, Governance and Guardrails, Runtime Security and Adversarial Assurance. The proposed approach is a multi-layered, adaptive approach to security that provides for continuous assurance throughout the AI lifecycle. It forms the conceptual basis for a more secure, resilient and trustworthy AI system in terms of its deployment.**

***Keywords*—** *Artificial Intelligence Security,Agentic AI, Runtime Security,Cyber Threat Intelligence, Threat Modeling.*

I. INTRODUCTION

Modern AI systems can reason, generate content, pull in external knowledge and perform actions via tools and APIs. This has fundamentally changed the cyber threat landscape. The traditional security model which is based on static trust boundaries, deterministic software and human authorisation at the point of action is simply not sufficient any more. Human in the loop controls will not be able to keep up with the speed of machine operation and the degree of autonomy of today's AI systems and so the effectiveness of human oversight is increasingly being eroded. [1,2]. The attack surface is no longer just application code and infrastructure. It now also encompasses prompts, embeddings, memory, model behaviour, retrieval pipelines and autonomous planning loops. [3]

Traditional security has been very much a human-in-the-loop affair with humans reviewing and either accepting, rejecting or correcting the ambiguous or unsafe outputs of the automated systems. That model worked very well in the low volume, low autonomy world we were in before. It's simply not viable in the current environment where we have AI systems that are generating thousands of outputs per minute, constantly ingesting data from the outside world and operating in a very fluid workflow. Human oversight in that scenario is just too slow, too expensive and too prone to cognitive fatigue to be the primary safety control. [4]

From a cyber threat intelligence perspective, the key thing for defenders to understand is how adversaries are going to exploit the vulnerabilities that are built into AI systems and how those threats are going to play out and evolve through the various stages of the AI lifecycle. The key attack techniques that are emerging are prompt injection, training data poisoning, retrieval based manipulation and all the various forms of manipulation that can happen via the malicious or unintended behaviour of autonomous AI agents. On the other side of the coin, defenders are also beginning to deploy a range of new automated tools to reduce their risk. These include digital safety guardrails, rule checking, multiple layers of filtering and AI tools that are designed to anticipate and stop the threat before it even happens.

Adversaries are also adapting to the same AI ecosystem. They're using AI to scale their reconnaissance, generate exploits, automate phishing, manipulate model behaviour and probe the defences. The defenders have to understand not just what the AI systems do but how they can be exploited, how the attacks will evolve and what controls are effective at each layer of the architecture. [5]

This paper argues that human-in-the-loop oversight is simply not sufficient for modern AI systems and that security needs to be baked in at every stage of the AI lifecycle (i.e. development, deployment, monitoring and governance.The remainder of this paper is organised as follows. Section II traces the historical evolution of the AI attack surface from traditional web applications to generative and agentic

systems. Section III outlines a practical defence blueprint grounded in cyber threat intelligence. Section IV concludes the paper.

.II. Evolution of the AI Attack Surface

A. Web Application Era

In the traditional web application world, the security issues were all about the application logic itself, authentication, authorization, data exposure and infrastructure availability. The classic security issues were SQL injection (SQLi), Cross-Site Scripting (XSS), broken access control, insecure deserialization, DoS etc. The security teams would have had a whole set of models that they would use to think about spoofing, tampering, repudiation, information disclosure, DoS and elevation of privilege [6]

The system architecture was static in that day. There is a web portal for displaying the application details, Application servers doing the processing, and the databases storing the results. A human would be making the operational and security decisions, and threat modelling would typically be done as part of the design review or as part of the annual assessment. [7].

B. Generative AI Era

The arrival of large language models (LLMs) and generative AI systems changed the nature of the application stack. Rather than deterministic software outputs, we now have probabilistic model responses. The advent of prompt-based interaction has in turn created new attack surfaces. Prompt injection has emerged as the AI-native equivalent of SQL injection, enabling an attacker to inject a prompt that alters the model's behaviour and circumvents policy boundaries [8].

Retrieval-augmented generation (RAG) pipelines add another layer of exposure. Security is no longer just about the model weights themselves; it's also about the security of the documents being retrieved, the vector stores, the embeddings and the indexing pipelines. If you have malicious or poisoned content in your retrieval layer, the model can be very confidently generating bad or misleading outputs.Other threats also came to the fore as being quite significant, namely hallucinations, which can lead to the spread of misinformation and the inadvertent disclosure of sensitive information via the model's outputs. The generative AI era therefore demands a new security mindset.[6].

C. Agentic and Autonomous Era

The agentic era is where AI goes beyond content generation into the world of action. Agents can now reason, plan, select tools, maintain memory and carry out multi-step workflows. In that world the model isn't just answering a question, it's making decisions and taking actions for the user or the organization [9].

This creates a vastly wider and more dangerous attack surface. You can have memory poisoning, goal hijacking, tool misuse, insecure credentials and agent identity confusion. In an autonomous system human involvement is going to be minimal. You might have a system that's running with only occasional human review, in which case the traditional approval workflows are not going to be sufficient. At that point the security boundary has to be enforced by the system itself rather than by a human reviewing every single decision [10]. Table I sets out the differences between the three eras.

TABLE I. Comparison of Security Characteristics Across Three Eras

Comparison Parameter	Web Application Era	Generative AI Era	Agentic and Autonomous Era
System architecture	Web portals, application servers, and databases	LLMs, RAG pipelines, vector stores, embeddings, and indexing pipelines	AI agents with reasoning, planning, tool selection, and memory capabilities
System behavior	Relatively stable, deterministic behavior as application servers process user requests	Probabilistic model responses instead of deterministic software outputs	Autonomous decision-making and execution of multi-step workflows
Major security threats	SQL injection, cross-site scripting, broken access control, insecure deserialization, and denial of service	Prompt injection, poisoned retrieval content, hallucinations, and sensitive information disclosure	Memory poisoning, goal hijacking, tool misuse, insecure credentials, and agent identity confusion
Human involvement	Humans typically make operational and security decisions	Human review of model outputs, increasingly strained by output volume	Reduced human involvement, potentially limited to periodic review

Comparison Parameter	Web Application Era	Generative AI Era	Agentic and Autonomous Era
Security approach	Conventional threat modelling using STRIDE [20], with design reviews or annual assessments	Addressing security risks associated with prompts, model outputs, and retrieval content	System-enforced security boundaries, because traditional human approval workflows may be inadequate

III. Proposed Cyber Threat Intelligence Blueprint

We propose a four-pillar approach to AI security: (1) Threat Understanding, (2) Governance and Guardrails, (3) Runtime Security and (4) Adversarial Assurance. This fully integrated security approach brings together threat intelligence, governance, and engineering, as shown in Fig. 1. The first pillar is Threat Understanding which is about doing systematic threat modelling across the models, the data pipelines, the tools, the agents and the application workflows. The second is Governance and Guardrails which is about establishing guardrails, policy constraints and oversight to govern the behaviour of the system and prevent it from doing something unsafe or unintended. The third is Runtime Security which is about securing the runtime environment via identity and access management, workload isolation, observability, logging and runtime protection. The fourth is Adversarial Assurance which is all about proactively ensuring the system is secure via adversarial testing, red teaming and penetration testing.Together, these form a multi-layered, adaptive security posture for AI systems. It's not just about individual controls, it's about continuous assurance across the AI lifecycle as autonomy, scale and attack surface all increase. [11]

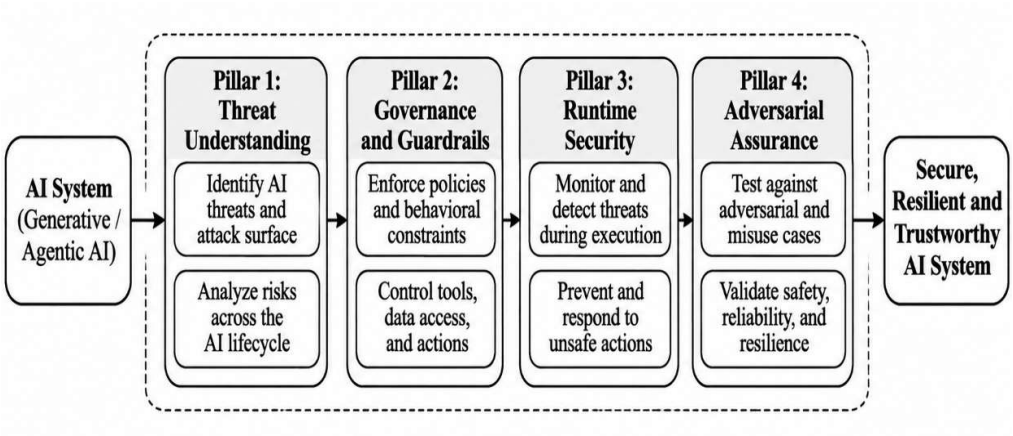


Fig. 1. Four-pillar blueprint for AI security.

A. Threat Understanding: Knowing what can go wrong.

This pillar is about systematic identification of risk throughout the AI lifecycle such as models, data pipelines, retrieval, tools, agents and user interaction. It's not sufficient to just do traditional software risk analysis. There is a need to do AI-specific threat modelling to identify the range of possible attacks such as prompt injection, data poisoning, model inversion, hallucination leading to misinformation, unbounded consumption, agent goal hijacking etc. The aim is to understand the potential failure modes, map them to the security architecture and then prioritize the security controls accordingly on the basis of impact and likelihood. That in turn moves security planning from a reactive model of responding to incidents to a proactive model of anticipating risk [12].

Knowing what can go wrong is the bedrock of AI security as it enables you to identify and prioritize risks prior to them becoming incidents. In the AI scenario , there is a need to be looking at threats across the model, the data pipeline, the retrieval, the tools, the agents and the user interactions rather than just the traditional software vulnerabilities. AI-specific threat modelling is about identifying things such as prompt injection, data and model poisoning, disclosure of sensitive information, excessive agency, the potential for misinformation and unbounded consumption [6]. The threats identified can be mapped to the security architecture and the use case to work out where your controls need to be and how likely various attack paths

are to succeed as shown in Fig 1. That is the essence of that pillar; it's about moving from a reactive to a proactive stance as the AI systems become more autonomous and more complex. [13].

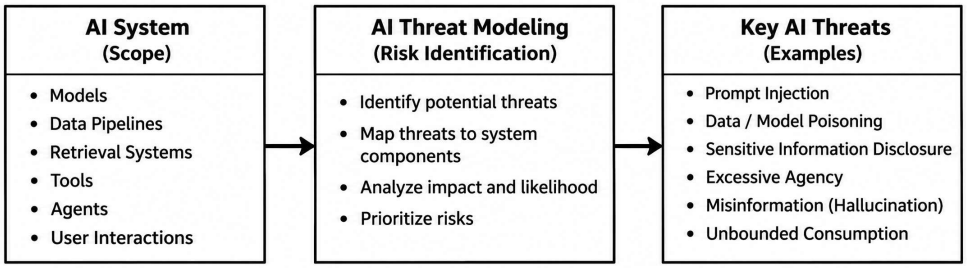


Fig. 2. Threat modeling view for identifying risks across AI system components.

B. Governance & Guardrails: Control What AI Can Do

This pillar focuses on constraining AI behavior through policy enforcement, guardrails, and governance mechanisms that define permissible actions, outputs, and tool usage. Instead of trusting models to self-regulate, organizations should implement layered controls such as deterministic filters, policy-based prompts, output validation, and restrictions on sensitive operations. In agentic environments, this includes controlling whether the system may execute actions, access external tools, or modify data without authorization. By embedding behavioral constraints into the architecture, organizations reduce the probability of unsafe, unauthorized, or unintended AI actions [14].

You need to define what the AI can and can't do in order to control it. The way to do this is to put in place a series of policy mechanisms which will enforce behavioral boundaries. You don't want the AI to self-regulate, you want it to be governed by a set of deterministic filters, prompt and policy-based constraints and a range of specialist guardrails. These can be used to prevent the disclosure of sensitive information, to block out unsafe or irrelevant content and to prevent the AI from doing things like invoking tools, modifying data or accessing external systems. In an agentic system this is particularly important as the AI may not just be producing a response but may be making decisions and taking actions. You therefore need to be able to govern what it is that it is permitted to decide, what it is that it is permitted to do and what it is that it is permitted to escalate (see Fig. 3). By putting these controls into the system design you significantly reduce the risk of misuse, policy violations and unintended autonomous behavior[15]. The Fig. 3 shows Guardrail-based control architecture for constraining AI behavior and outputs.

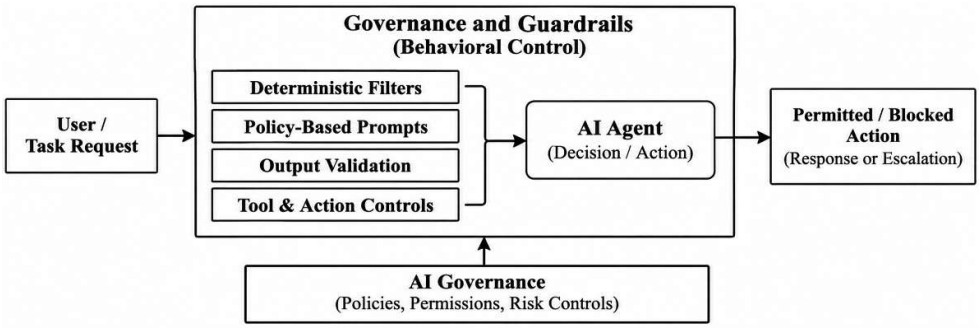


Fig. 3. Guardrail-based control architecture for constraining AI behavior and outputs.

C. Runtime Security: Secure Where AI Runs

This pillar is about the protection of the infrastructure, the runtime and the operational environment in which the AI system is running. It covers identity and access management, workload isolation, observability, logging, auditability and continuous monitoring of the AI components, tools and agents. In systems which have autonomous behaviour, a compromise of the infrastructure can lead to the manipulation of the models, the memory or the connected services and so runtime security is a critical control layer. Effective implementation of this pillar will also require incident response capability and where appropriate the availability of kill-switches to isolate or disable a compromised component. Securing the execution environment is the technical bedrock upon which trustworthy AI can be deployed [16].

Securing where the AI runs is about securing the execution environment in which the models, agents, tools, and data operate. That means strong identity and access controls, workloads being isolated, system activity being monitored, tamper-resistant logging and the ability to detect anomalies in real time. In the case of AI and agentic systems the infrastructure layer is of particular importance as a compromise at this level can lead to the models being accessed unauthorized, the models being compromised, the outputs being altered, the memory being manipulated and the agent being able to perform rogue actions via its connected tools and services. Good runtime security also requires good incident response capability and in some cases the ability to have a kill switch that allows an operator to disable or quarantine a compromised component (see Fig 4). Securing the environment beneath the model is a key enabler of a more resilient and trustworthy AI deployment.[17].

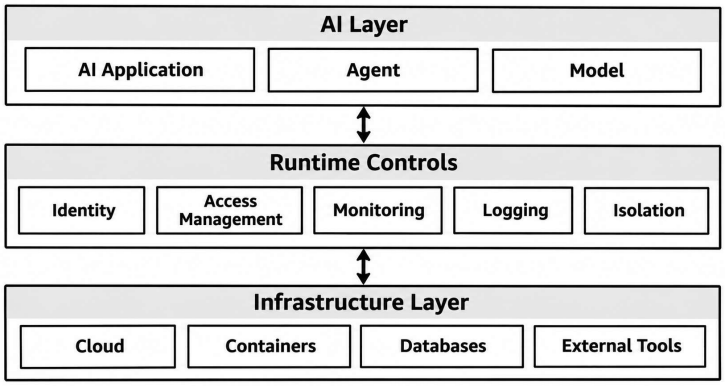


Fig. 4. Runtime security architecture for protecting the environment in which AI systems operate.

D. Adversarial Assurance: Break It Before Attackers Do.

This pillar is about active assurance via adversarial testing (red teaming, penetration testing, attack simulation) prior to deployment and throughout the lifecycle. The objective is to work out whether the security controls are actually going to stop a real attack (e.g. prompt injection, leakage of sensitive data, exploitation of tools, supply chain abuse). The idea is to actively test the controls to see whether they actually work in the face of a real attack and thereby validate your guardrails, your governance rules and your runtime defences. It allows you to fix things early and makes the system more resilient to the kinds of attacks that are going to be used. [18]

Breaking it before the attackers do means proactively testing AI systems to find the vulnerabilities before they can be exploited in the real world. This is all about red teaming, adversarial evaluation, penetration testing and sandboxed simulations to see how the system behaves when under attack (e.g. prompt injection, sensitive data exfiltration, tool misuse, supply chain manipulation). The aim is to verify that the guardrails, the governance rules and the runtime controls actually work when facing real world adversarial behaviour (see Fig. 5). The more you can probe the system and fix the issues you find early on the better you will be at avoiding incidents in production as the AI systems themselves continue to mature. [19].

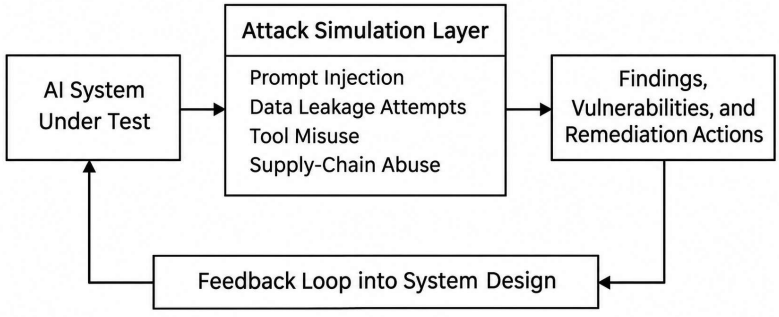


Fig. 5. Proactive adversarial testing workflow for identifying and remediating AI security weaknesses before attackers exploit them.

IV. Conclusion

Human in the loop control is simply not good enough in today's AI ecosystems. Moving from generative AI to agentic and autonomous systems demands a far more robust, layered and continuously adaptive security posture. This paper has demonstrated the difference that AI-native threats make to the threat landscape when compared to the classical web threats we've been used to. Guardrails and governance are the very foundation of a resilient defense. From a cyber threat intel point of view the future of AI security is continuous modelling, proactive testing, automated governance and defense in depth. The organizations that get these principles embedded from the outset will be in the best position to deploy AI safely and sustainably.

References

[1] H. Zhu, H. Sato, J. Ma, T. Cerny, A. Muñoz, and A.M. Alberti, Agentic AI: An Emerging Paradigm of Computing? Panel Discussion at IEEE CISOSE 2026, *IEEE International Conference on Big Data Computing Service and Machine Learning Applications (BigDataService)*, pp. 1–8 (2026). doi:10.1109/bigdataservice70481.2026.00054.

[2] R.V. Yampolskiy, On monitorability of AI. *AI and Ethics* **5**, 689–707 (2024). doi:10.1007/s43681-024-00420-x.

[3] Hang Su, Jun Luo, Chang Liu, Xiao Yang, Yichi Zhang, Yinpeng Dong, and Jun Zhu, "A Survey on Autonomy-Induced Security Risks in Large Model-Based Agents*," IEEE Transactions on Pattern Analysis and Machine Intelligence, vol. 48, pp. 11382–11401, Oct. 2026*, doi: 10.1109/TPAMI.2026.3688650.

[4] A. Tsamados, L. Floridi, and M. Taddeo, Human control of AI systems: from supervision to teaming. *AI and Ethics* **5**, 1535–1548 (2024). doi:10.1007/s43681-024-00489-4.

[5] N. Kaloudi and J. Li, The AI-Based Cyber Threat Landscape. *ACM Computing Surveys* **53**, 1–34 (2020). doi:10.1145/3372823.

[6] N.E.D. Ferreyra, M.M. Kumar, N. Villarreal, P. Pantel, I. Brueggemann, and R. Scandariato, Emerging Challenges in Threat Modeling for GenAI-Augmented Systems: A View from the Trenches. *Leibniz International Proceedings in Informatics (LIPIcs)* (2026). doi:10.4230/lipics.esem.2026.57.

[7] R. Almanasir, D. Al-solomon, S. Indrawes, M.A. Almaiah, U. Islam, and M. Alshar'e, Classification of threats and countermeasures of cloud computing. *Journal of Cyber Security and Risk Auditing* **2025**(2), 27–42 (2025). doi:10.63180/jcsra.thestap.2025.2.3.

[8] A.V. Nyayapathi, Prompt Injection Is the New SQL Injection: Why LLM Security Will Define the Next Decade. *Zenodo* (2026). doi:10.5281/zenodo.18925240.

[9] R. Sapkota, K.I. Roumeliotis, and M. Karkee, AI Agents vs. Agentic AI: A Conceptual taxonomy, applications and challenges. *Information Fusion* **126**, 103599 (2025). doi:10.1016/j.inffus.2025.103599.

[10] A. Bandi, B. Kongari, R. Naguru, S. Pasnoor, and S.V. Vilipala, The Rise of Agentic AI: A Review of Definitions, Frameworks, Architectures, Applications, Evaluation Metrics, and Challenges. *Future Internet* **17**, 404 (2025). doi:10.3390/fi17090404.

[11] R.A. Al-Horani and A.F. Tadesse, Continuous assurance for AI-driven clinical decision support systems. *Frontiers in Artificial Intelligence* **9**, 1870819 (2026). doi:10.3389/frai.2026.1870819.

[12] Jonas C. Ditz, Veronika Lazar, Elmar Lichtmeß, Carola Plesch, Matthias Heck, Kevin Baum, and Markus Langer, "Secure Human Oversight of AI: Threat Modeling in a Socio-Technical Context," in *Proceedings of the Ninth AAAI/ACM Conference on AI, Ethics, and Society (AIES 2026), 2026*, pp. 843–856.

[13] N.A. Mohamed, Artificial intelligence and machine learning in cybersecurity: a deep dive into state-of-the-art techniques and future paradigms. *Knowledge and Information Systems* **67**, 6969–7055 (2025). doi:10.1007/s10115-025-02429-y.

[14] T. Miller, Controlled Agentic AI Systems: A Governance-Driven Architecture for Auditable and Reproducible Decision Pipelines. *Preprints.org* (2026). doi:10.20944/preprints202603.1904.v1.

[15] B.N. Jôrgensen and Z.G. Ma, Governing Agentic AI in Enterprise Workflows: A Bounded-Autonomy Framework for Delegated Authority and Controlled Execution. *Information* **17**, 923 (2026). doi:10.3390/info17090923.

[16] P. Gidwani, Protecting AI From Malicious Threats (Security), pp. 59–82 (2026). doi:10.4018/979-8-3373-6935-8.ch003.

[17] I. Arshad, S.H. Alsamhi, Y. Qiao, B. Lee, and Y. Ye, A Novel Framework for Smart Cyber Defence: A Deep-Dive Into Deep Learning Attacks and Defences. *IEEE Access* **11**, 88527–88548 (2023). doi:10.1109/access.2023.3306333.

[18] Didunoluwa Olukoya, Samson Onaopemipo Amoran, Oluwatosin Lawal, Malik Altawati, Saadat O. Ibiyeye, Abdulaziz O. Ibiyeye, and Osondu C. Onwuegbuchi, "Data Security and Governance in the Age of AI-Enabled Attacks," *World Journal of Advanced Research and Reviews, vol. 28, no. 3, pp. 1713–1722, 2025*, doi: 10.30574/wjarr.2025.28.3.4267.

[19] A.K. Kanagala, Autonomous Security Testing for AI Systems: Evaluating AI Red-Teaming Agents for Continuous Adversarial Assessment and Model Resilience. *Applied Sciences Research Periodicals* **4**, 191–201 (2026). doi:10.63002/asrp.401.1330.

[20] Adam Shostack, "STRIDE," in Threat Modeling: Designing for Security , Wiley, 2014, pp.61-86.